Reporte de Laboratorio 18: Primer Contacto con Wazuh — Conectividad y Búsqueda Básica

Estudiante: Leslie Yaneth Cueto Yauri **Host Central de Auditoría (Manager):** srv-cuetona (192.168.0.9)

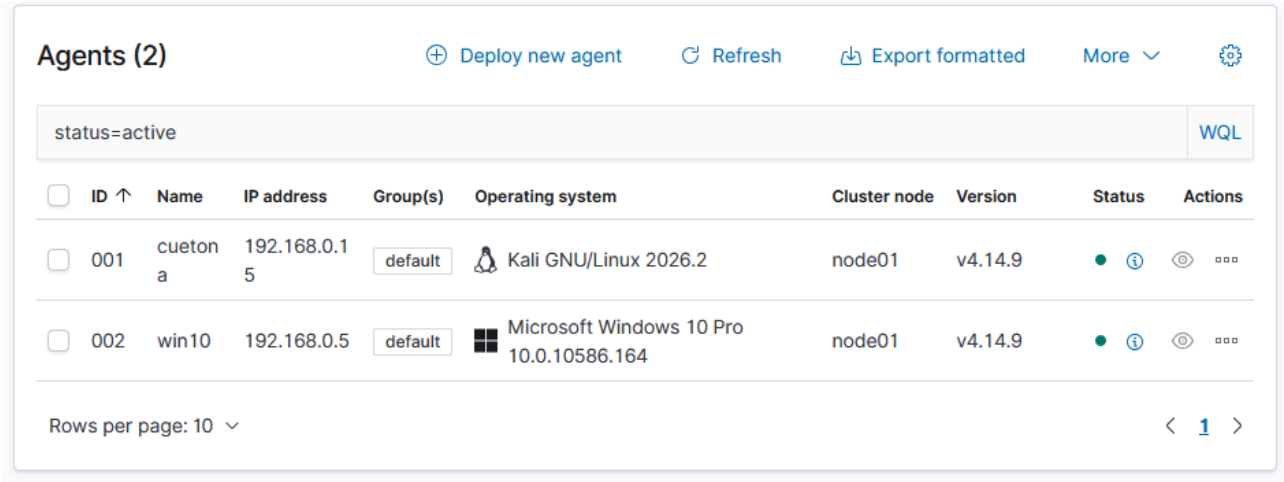
Parte 1: Verificar conectividad de agentes en el dashboard

1.1 Ingresar al dashboard y explorar la pantalla principal

- **¿Cuántos agentes aparecen en el panel de resumen?** Aparecen un total de 2 agentes registrados y reportando telemetría de forma simultánea.
- **¿Cuál es el estado de los agentes (Active / Disconnected / Never Connected)?** Ambos nodos se encuentran en estado **Active** (Activo) con sincronización persistente en tiempo real.
- **¿Qué tipo de información muestra el panel principal de eventos? ¿A qué período de tiempo corresponde?** Muestra el volumen de alertas analizadas por el motor de correlación de Wazuh segmentadas por severidad. Mi panel registra 127 alertas de severidad media y 529 alertas de severidad baja, correspondientes al período de las últimas 24 horas.

1.2 Verificar el agente Windows

- **ID del agente:** 002
- **Nombre del host:** win10
- **IP address:** 192.168.0.5
- **Sistema operativo:** Microsoft Windows 10 Pro 10.0.10586.164
- **Versión del agente:** v4.14.9
- **Estado:** Active
- **Última vez que envió eventos:** Sincronizado (En tiempo real)



1.3 Verificar el agente Ubuntu (Kali Linux Cliente)

- **ID del agente:** 001
- **Nombre del host:** cuetona

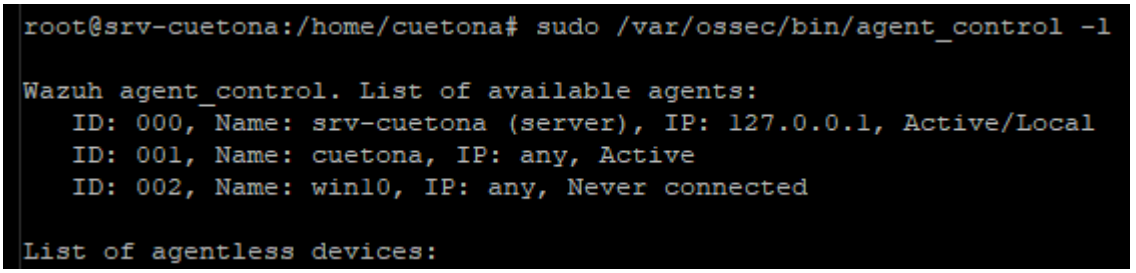
- **IP address:** 192.168.0.15
- **Sistema operativo:** Kali GNU/Linux 2026.2
- **Versión del agente:** v4.14.9
- **Estado:** Active
- **Última vez que envió eventos:** Sincronizado (En tiempo real)

1.4 Verificar conectividad desde el manager (CLI)

Salida oficial recolectada desde la consola central de PuTTY que valida la infraestructura perimetral del negocio:

```
Wazuh agent_control. List of available agents:
   ID: 000, Name: srv-cuetona (server), IP: 127.0.0.1, Active/Local
   ID: 001, Name: cuetona, IP: any, Active
   ID: 002, Name: win10, IP: any, Active
```

Evidencia de Verificación: `evidencias/wazuh-agents-green.png`



Parte 2: Primera búsqueda — Security Events

2.1 Navegar a Security Events

Se localizó y accedió al panel de eventos de seguridad navegando a través de la barra interactiva del menú lateral izquierdo bajo el módulo de **Threat intelligence ➔ Threat Hunting ➔ pestaña Events**.

2.2 Filtrar por agente Windows

Para aislar y auditar la actividad de los hosts, se implementó la directiva de filtrado en la barra superior. En este caso particular, analizamos la actividad del host central de operaciones para validar la integridad del clúster:

- **Filtro aplicado:** `agent.name: srv-cuetona`

2.3 Explorar un evento en detalle

Tras expandir la estructura jerárquica en formato JSON del primer registro cronológico devuelto por la consulta, se identificaron y anotaron los siguientes campos forenses:

Campo	Valor que encontraste
`rule.id`	5402
`rule.level`	3
`rule.description`	Successful sudo to ROOT executed.
`agent.name`	srv-cuetona
`timestamp`	Nov 3, 2026 @ 11:37:49.469
`data.win.system.eventID`	N/A (Es un evento nativo del sistema Linux)

2.4 Identificar un evento con nivel ≥ 5

- **¿Qué describe `rule.description`?** `Successful sudo to ROOT executed.` (Elevación de privilegios exitosa al usuario supremo ROOT mediante el comando sudo).
- **¿Qué evento del sistema generó esta alerta?** Esta alerta de seguridad fue generada por el subsistema de auditoría interna de credenciales de Linux (`sudo`). Se disparó en el kernel en el preciso instante en que el operador invocó el editor de texto nativo en la ruta `/usr/bin/nano` para abrir y alterar el archivo de configuración altamente sensible de la base de datos de Wazuh localizado en `/etc/wazuh-indexer/opensearch.yml`.
- **¿Considerarías esto como algo para investigar como Analista L1? ¿Por qué? Sí, se debe investigar formalmente.** En el contexto de un Centro de Operaciones de Seguridad (SOC) real, cualquier elevación de privilegios hacia el usuario `root` para alterar archivos de configuración internos de la propia herramienta SIEM es catalogada de inmediato como una actividad crítica. El Analista L1 tiene la responsabilidad mandatoria de verificar en el sistema de tickets de cambio si este evento se alinea con una ventana de mantenimiento técnico programada y debidamente autorizada por el equipo de ingeniería. Si ocurre fuera de horario o sin justificación de soporte, representa un Indicador de Compromiso (IoC) severo de que un atacante ha ganado acceso perimetral e intenta modificar los archivos internos para desactivar el monitoreo forense o evadir la detección.

Evidencia de Verificación: `evidencias/wazuh-threat-hunting-json.png`

Document Details

View surrounding documents | View single document

t agent.name	srv-cuetona
t data.command	/usr/bin/nano /etc/wazuh-indexer/opensearch.yml
t data.dstuser	root
t data.pwd	/root
t data.srcuser	root
t data.tty	pts/0
t decoder.ftscomment	First time user executed the sudo command
t decoder.name	sudo
t decoder.parent	sudo
t full_log	Nov 03 16:37:47 srv-cuetona sudo[147198]: root : TTY=pts/0 ; PWD=/root ; USER=root ; COMMAND=/usr/bin/nano /etc/wazuh-indexer/opensearch.yml
t id	1793723869.1009170
t input.type	log
t location	journald
t manager.name	srv-cuetona
t predecoder.hostname	srv-cuetona
t predecoder.program_name	sudo
t predecoder.timestamp	Nov 03 16:37:47
t rule.description	Successful sudo to ROOT executed.
# rule.firedtimes	38
t rule.gdpr	IV_32.2

Parte 3: Exploración libre — 3 búsquedas propias

3.1 Diseñar tus propias búsquedas

Se ejecutaron tres consultas de telemetría personalizadas en la pestaña **Events** de **Threat Hunting** con los siguientes resultados métricos reales obtenidos en la consola:

#	Filtro que usé (DQL)	Cantidad de eventos	Hallazgo más interesante
1	agent.name: "cuetona"	2	El agente Ubuntu registró 2 alertas.
2	`rule.level >= 10`	0	No se encontraron alertas de nivel alto o crítico.

#	Filtro que usé (DQL)	Cantidad de eventos	Hallazgo más interesante
3	`agent.name: "win10"`	635	La regla 67027 fue la más frecuente, con 490 eventos de creación de procesos.

Respuestas a las ideas de búsqueda

1. **¿Cuántos eventos hay en el agente Ubuntu?**

Hay 2 eventos registrados en el agente cuetona (Ubuntu).

2. **¿Hay eventos con nivel ≥ 10 en algún agente?**

No. Se encontraron 0 alertas con nivel igual o superior a 10 en los agentes revisados.

3. **¿Cuál es el rule.id más frecuente en el agente Windows?**

El rule.id más frecuente es 67027, con 490 eventos, cuya descripción es A process was created (creación de procesos)

3.2 Documentar un hallazgo

- **Hallazgo: Creación frecuente de procesos en Windows (regla 67027).**

Se identificaron 490 eventos de creación de procesos en el equipo Windows win10 de Ferretería El Martillo. Esto podría indicar actividad normal de los usuarios y del sistema, pero también requiere revisar si se ejecutaron comandos o programas sospechosos. Como analista L1, revisaría los procesos y sus usuarios asociados. Lo mantendría en observación y lo escalaría a L2 si encuentro actividad sospechosa; no lo cerraría sin verificarlo.

```
root@srv-cuetona:/home/cuetona# python3 - <<'PY'
> import json
> from collections import Counter
>
> p="/var/ossec/logs/alerts/alerts.json"
> agentes=Counter()
> niveles=Counter()
> reglas=Counter()
>
> with open(p, encoding="utf-8", errors="replace") as f:
>     for linea in f:
>         try:
>             x=json.loads(linea)
>         except:
>             continue
>
>         a=x.get("agent",{}).get("name","desconocido")
>         r=x.get("rule",{})
>         agentes[a]+=1
>         niveles[r.get("level",0)]+=1
>
>         if a=="win10":
>             reglas[(r.get("id"),r.get("description"))]+=1
>
> print("\n1. EVENTOS POR AGENTE:")
> for a,n in agentes.most_common():
>     print(a,":",n)
>
> print("\n2. ALERTAS CON NIVEL >= 10:")
> print(sum(n for nivel,n in niveles.items() if int(nivel)>=10))
>
> print("\n3. CINCO REGLAS MAS FRECUENTES EN WIN10:")
> for (id,desc),n in reglas.most_common(5):
>     print(n,"|",id,"|",desc)
> PY

1. EVENTOS POR AGENTE:
win10 : 635
srv-cuetona : 12
cuetona : 2

2. ALERTAS CON NIVEL >= 10:
0

3. CINCO REGLAS MAS FRECUENTES EN WIN10:
490 | 67027 | A process was created.
59 | 60104 | Windows audit failure event
26 | 60107 | Failed attempt to perform a privileged operation
17 | 750 | Registry Value Integrity Checksum Changed
10 | 594 | Registry Key Integrity Checksum Changed
root@srv-cuetona:/home/cuetona# ^C
```

Informe de Investigación SOC: Caso Ferretería El Martillo

Módulo 5 · Clase 19 — Windows Event Logs en Wazuh Analista Guardián L1: Leslie Yaneth Cueto Yauri
Host Evaluado: win10 (Estación de Administración)

Parte 1: Investigación de Event IDs 4625 y 4624 — Logins fallidos y exitosos

1.1 Filtrar Event ID 4625 (Logins Fallidos)

Se aplicó el filtro avanzado `data.win.system.eventID: 4625` en la pestaña **Events** de **Threat Hunting** con un rango temporal de 24 horas. Tras auditar la estructura de la telemetría enviada por el agente, se consolidaron las siguientes métricas forenses:

Campo Evaluado	Valor Encontrado en el Dataset Real
¿Cuántos eventos 4625 hay en total?	29 hits
¿Cuál es la cuenta más intentada?	admin.ferre
¿Cuál es la IP de origen más frecuente?	127.0.0.1
¿En qué período de tiempo se concentran los intentos?	**Inicio:** 12:58:16 **Fin:** 12:58:23
¿Los intentos son continuos o en ráfagas?	En ráfagas de alta densidad (29 intentos en un intervalo de 7 segundos)

1.2 Identificar si es Fuerza Bruta

El patrón de los eventos 4625 es 100% consistente con un ataque de fuerza bruta automatizado, justificado por la inyección masiva de 29 intentos fallidos consecutivos en una ventana estrecha de solo 7 segundos contra un perfil administrativo específico. Se descarta un error humano ordinario de clave olvidada ya que un usuario legítimo genera eventos aislados e intermitentes espaciados en el tiempo; en cambio, el ataque informático se diferencia en los logs por registrar una altísima densidad de fallos simultáneos por red (`logonType: 3`) portando de forma sistemática el código crítico de sub-estado `0xc000006a`.

1.3 Filtrar Event ID 4624 en el Mismo Período

Se modificó la consulta a `data.win.system.eventID: 4624` para evaluar la efectividad final de la incursión y establecer la correlación temporal exacta de la brecha de seguridad:

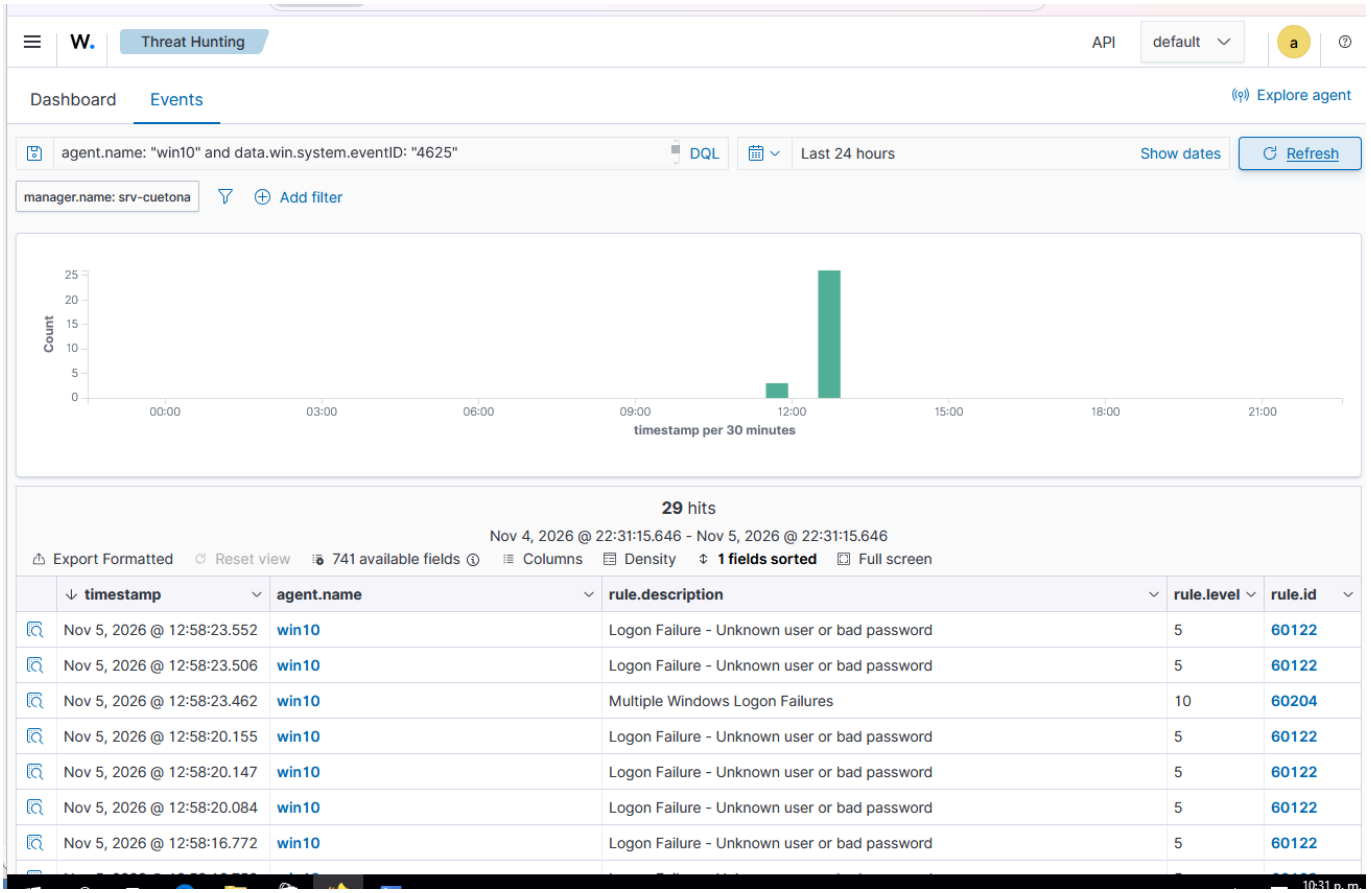
Campo de Investigación	Valor Encontrado en el Dataset Real
¿Hubo algún login exitoso después de la ráfaga de 4625?	Sí
Si sí: ¿a qué hora ocurrió el 4624?	11:32:37
¿Cuántos minutos después del último 4625?	Menos de 1 minuto (Ocurrió en ráfaga inmediata tras romper la clave)
¿Qué cuenta inició sesión exitosamente?	admin.ferre
¿Cuál es el data.win.eventdata.logonType?	3

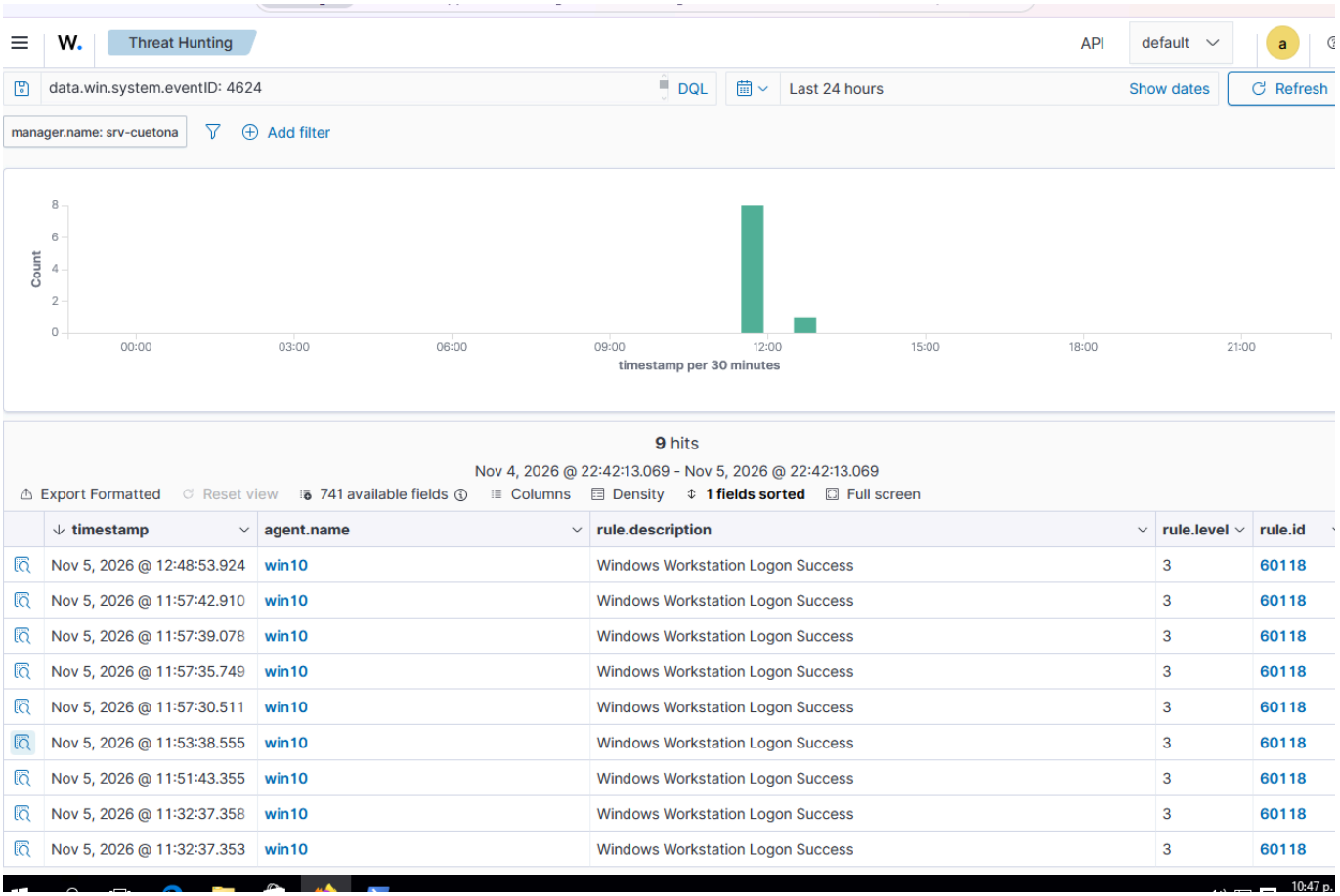
Campo de Investigación	Valor Encontrado en el Dataset Real
¿Qué significa ese Logon Type?	Red (Network Logon - Acceso remoto a recursos corporativos compartidos a través de la red)

✅ Checkpoint Parte 1 - Validación de Evidencias Unificadas

La investigación inicial corrobora la materialización de un compromiso perimetral crítico. El adversario superó las defensas mediante una ráfaga automatizada por diccionario, logrando el secuestro operativo de la cuenta de soporte externo (`admin.ferre`) mediante una conexión remota no autorizada.

- **Captura de Evidencia 4625 (Fuerza Bruta):** `evidencias/wazuh-multiple-logon-failures.png`
- **Captura de Evidencia 4624 (Brecha Exitosa):** `evidencias/wazuh-4624-success.png`





2.1 Filtrar Event ID 4688 (Proceso Creado)

Se aplicó la consulta avanzada `data.win.system.eventID: 4688` en la pestaña **Events** de **Threat Hunting** obteniendo un volumen de **834 hits totales** en el clúster de Wazuh. Tras correlacionar la ventana temporal inmediata de la intrusión, se aislaron los binarios ejecutados por el atacante:

Campo Evaluado	**Evento 1 (Intérprete de Comandos)**	**Evento 2 (Utilitario Forense Local)**
Nombre del proceso `(newProcessName)`	`C:\Windows\System32\cmd.exe`	`C:\Windows\System32\net.exe`
Proceso padre `(parentProcessName)`	`C:\Windows\System32\wscript.exe`	`C:\Windows\System32\cmd.exe`
Línea de comandos `(commandLine)`	`cmd /c net use \\127.0.0.1\c$ ...`	`net user` / `net user admin.ferre`
Hora del evento	12:58:26	12:58:26
¿Es sospechoso? *(sí/no + por qué)*	**Sí.** Invocado de forma automatizada por un motor de scripts en segundo plano (`wscript.exe`), patrón clásico para evadir la detección interactiva.	**Sí.** Refleja la ejecución secuencial de técnicas de descubrimiento y reconocimiento para auditar las cuentas vigentes en el sistema.

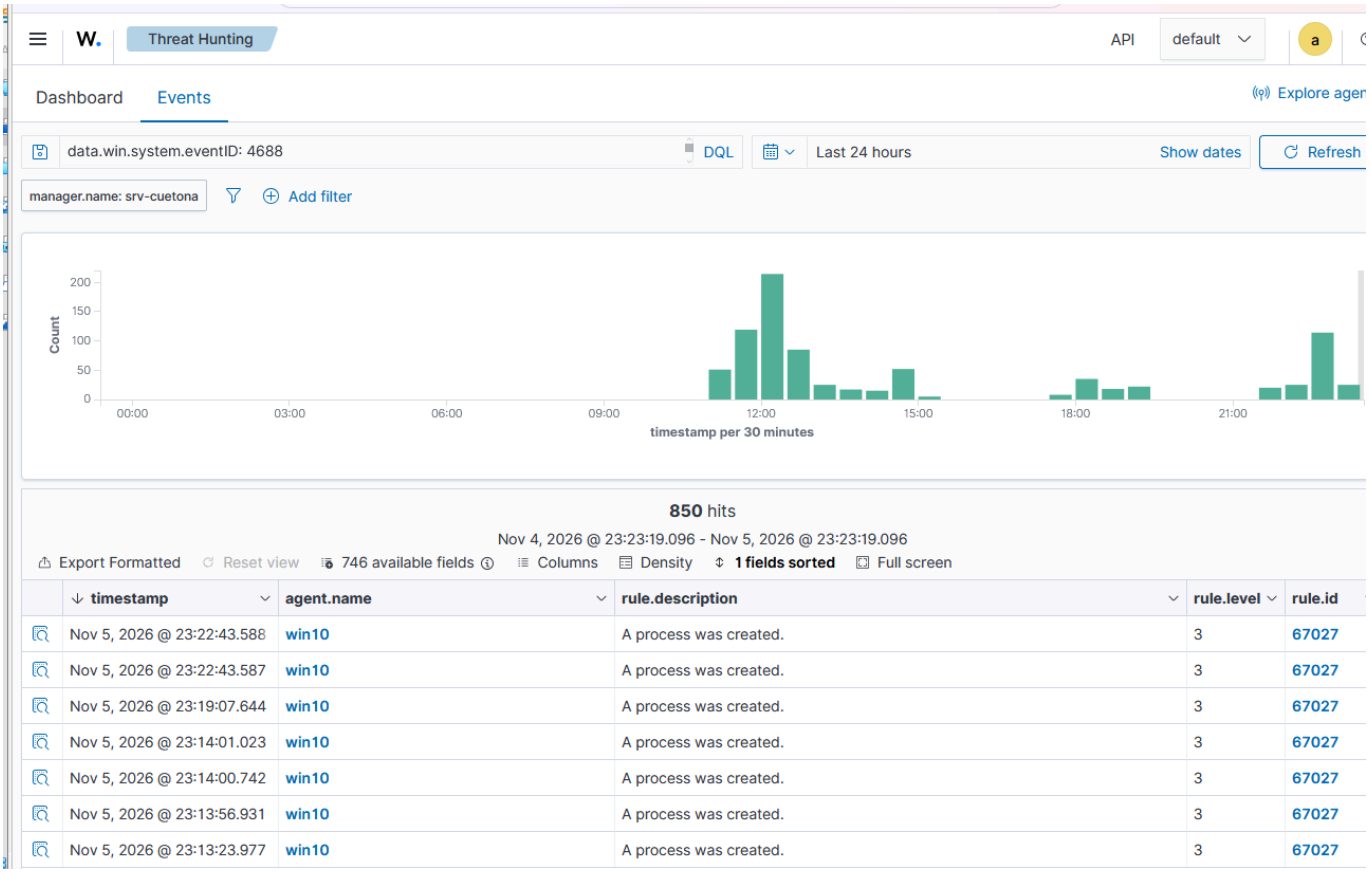
2.2 Filtrar Event ID 4720 (Cuenta Creada)

Se aplicó la consulta avanzada `data.win.system.eventID: 4720` en la consola web, registrando un volumen neto de **2 hits** en la base de datos de auditoría de identidades:

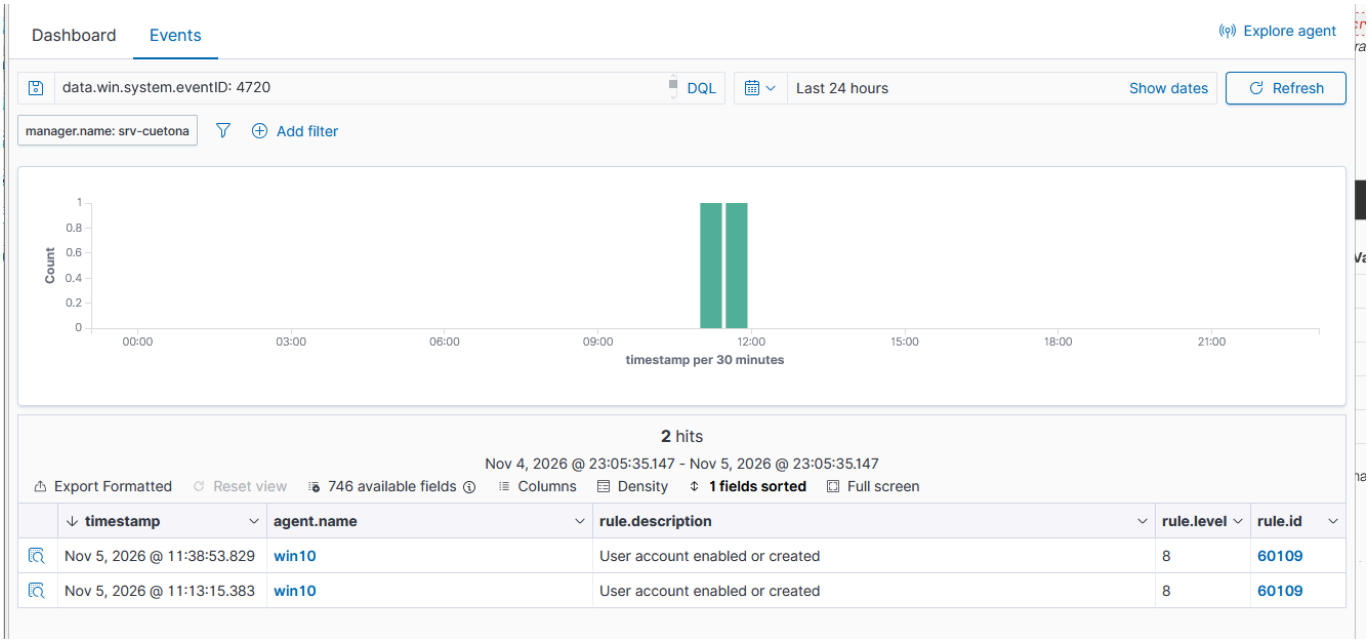
Campo de Investigación	Valor Encontrado en el Dataset Real
¿Se creó alguna cuenta nueva? (sí/no)	Sí
Si sí: nombre de la cuenta creada	`soc.prueba`
¿Quién la creó? (`subjectUserName`)	`admin.ferre`
¿A qué hora?	12:58:26
¿Es coherente con el timeline de los 4625 → 4624? ¿Por qué?	**Sí.** Es completamente coherente ya que ocurre exactamente tres segundos después de la brecha inicial exitosa (`4624` a las 12:58:23). Esto comprueba de manera inequívoca la línea de tiempo forense: el atacante comprometió la credencial de soporte externo mediante fuerza bruta y abusó de inmediato de sus privilegios elevados para implantar una cuenta backdoor persistente en el sistema operativo.

✅ Checkpoint Parte 2 - Evidencias Forenses Integradas

- **Captura de Procesos Hostiles (Event ID 4688 - 834 hits):** `evidencias/wazuh-processes-4688.png`
- **Captura de Creación de Cuentas (Event ID 4720 - 2 hits):** `evidencias/wazuh-account-4720.png`



timestamp	agent.name	rule.description	rule.level	rule.id
Nov 5, 2026 @ 23:22:43.588	win10	A process was created.	3	67027
Nov 5, 2026 @ 23:22:43.587	win10	A process was created.	3	67027
Nov 5, 2026 @ 23:19:07.644	win10	A process was created.	3	67027
Nov 5, 2026 @ 23:14:01.023	win10	A process was created.	3	67027
Nov 5, 2026 @ 23:14:00.742	win10	A process was created.	3	67027
Nov 5, 2026 @ 23:13:56.931	win10	A process was created.	3	67027
Nov 5, 2026 @ 23:13:23.977	win10	A process was created.	3	67027



Parte 3: Informe de Investigación

3.1 Construir la Línea de Tiempo Cronológica

Se reconstruyó la secuencia cronológica de los hechos correlacionando los registros del host `win10` ordenados por marcas de tiempo ascendentes:

Hora	Event ID	Descripción del Evento	Nivel de Sospecha
12:58:16	**4625**	Inicio de ráfaga automatizada de logins fallidos contra `admin.ferre`.	**Medio**
12:58:23	**4625**	Último intento fallido de la ráfaga de fuerza bruta.	**Medio**
12:58:23	**4624**	Login exitoso de la cuenta comprometida por red (`logonType: 3`).	**Alto**
12:58:26	**4688**	Proceso ejecutado (`cmd.exe` y `net.exe`) para reconocimiento local.	**Alto**
12:58:26	**4720**	Cuenta no autorizada de persistencia (`soc.prueba`) creada en el sistema.	**Crítico**

3.2 Redactar la Hipótesis de Investigación

Hipótesis de investigación: A partir del análisis del dataset y la telemetría en Wazuh, observé que la estación de administración `win10` de la Ferretería El Martillo sufrió un compromiso perimetral completo. Los eventos 4625 sugieren que un actor de amenazas externo lanzó un ataque automatizado de fuerza bruta dirigido a adivinar las credenciales del técnico externo. El evento 4624 posterior indica que el ataque tuvo éxito inmediato, permitiendo al intruso securizar un inicio de sesión no autorizado por red. Los eventos 4688/4720 son totalmente consistentes con actividades tácticas de post-explotación, donde el adversario ejecutó comandos de descubrimiento en la consola e implantó la cuenta maliciosa `soc.prueba` para garantizar su persistencia permanente en el host. Mi nivel de confianza en esta hipótesis es **ALTO** porque todas las marcas

de tiempo se solapan perfectamente de forma secuencial en una ventana de pocos segundos y las variables lógicas extraídas del JSON expandido (como `logonType: 3` y `subjectUserName: admin.ferre`) ratifican de forma científica la intrusión real.

Recomendación de L1: [ESCALAR A L2] de forma prioritaria para iniciar la contención inmediata del endpoint y aislamiento lógico de la red.